

Pflichtenheft - auth-service - Version 1.1 (Minor)

Service-Name	auth-service
Version	1.1 (Minor)
Stand	25.02.2026
Ziel	Konsolidierung des Token- und Tenant-Contracts für alle Backend-Services (FlowTrack v2.1 ohne KI) sowie Ergänzung verbindlicher Service-Token- und Idempotency-Regeln.
Geltungsbereich	Authentifizierung, Session-Management, Registrierung/Onboarding, JWT Issuer (JWKS), Refresh-Sessions, Logout, Recovery.

0. Änderungshistorie (gegenüber V1.0)

- Token-Contract v1.1 wird normativ: aud immer als Array, scp immer als Array, subject_type verpflichtend.
- Standardisierte Mandanten- und Request-Konventionen (tenant_id, optional X-Tenant-Id, X-Correlation-Id, Idempotency-Key).
- Service Tokens: Implementationspflicht für Auth-interne Downstream-Calls (Messaging/Template/Delivery, User/Company/IAM).
- Idempotency-Storage für kritische POST-Endpunkte (24h Retention).

1. Ziele

- Alle Resource-Services können JWTs einheitlich validieren (Issuer/JWKS, Audience, Claims).
- tenant_id ist systemweit Quelle der Wahrheit (Zero Cross-Tenant).
- Kritische Flows sind retry-sicher (Idempotency) und auditierbar (Correlation).

2. In Scope / Out of Scope

In Scope:

- Anpassung der ausgestellten Access Tokens (Claims/Struktur) nach Token-Contract v1.1.
- Ausstellung kurzlebiger Service Tokens für interne Calls.
- Idempotency-Key Handling für definierte Endpunkte.

Out of Scope:

- Vollständiges RBAC/Permissions-Modell (Quelle der Wahrheit: IAM).
- Globale Token-Blacklist für sofortigen Logout über alle Devices.

3. Token-Contract v1.1 (verbindlich)

Pflicht-Claims:

- iss, sub, aud, iat, exp, jti, tenant_id
- subject_type (USER | SERVICE)
- scp (Array) führend; scope (String) optional (Legacy)

Empfohlen:

- sid (Session-ID), amr (enthält "totp"), auth_time
- token_version = "1.1"

Audience-Regel:

- aud ist ein Array und enthält mindestens den Zielservice (z. B. "user-service").
- Resource-Services prüfen aud strikt (kein Wildcard).

Tenant-Regel:

- Wenn ein Request zusätzlich Tenant-Angaben enthält (Path/Header/Query), müssen diese dem tenant_id Claim entsprechen, sonst 403 TENANT_MISMATCH.

4. Service Tokens (MUSS)

- Service Tokens werden für Auth-interne Service-zu-Service Calls verwendet.
- subject_type="SERVICE", sub="auth-service".
- aud enthält genau den Zielservice.
- exp kurz: 2-5 Minuten.
- scp minimal (Least Privilege), z. B. ["user:provision"].
- tenant_id wird gesetzt, wenn der Zielservice tenant-scharf ist.

Endpoint (intern):

- POST /api/v1/internal/tokens/service

Request: { "aud": "user-service", "tenantId": "TEN_...", "scp": ["user:provision"], "ttlSeconds": 300 }

Response: { "accessToken": "...", "expiresIn": 300 }

5. Request-Konventionen (systemweit)

Headers:

- X-Correlation-Id (SOLL): wird übernommen oder generiert; wird immer im Response zurückgegeben.
- Idempotency-Key (MUSS) für kritische POSTs (siehe Abschnitt 6).
- X-Tenant-Id (KANN): Wenn vorhanden, muss es tenant_id entsprechen (sonst 403).

Fehlerformat:

- Standard Error DTO: timestamp, status, errorCode, message, correlationId, path, details[]

6. Idempotency (MUSS)

Pflicht-Endpunkte für Idempotency-Key:

- /api/v1/registration/start
- /api/v1/registration/verify-email
- /api/v1/registration/mfa/totp/confirm
- /api/v1/auth/login
- /api/v1/auth/mfa/verify
- /api/v1/password/forgot
- /api/v1/password/reset
- /api/v1/mfa/recovery/start
- /api/v1/mfa/recovery/confirm

Regel:

- Gleicher Key + gleicher Endpoint + gleicher Kontext => gleiche Antwort.
- Bei Payload-Abweichung: 409 IDEMPOTENCY_CONFLICT.

Retention:

- Speicherung der Idempotency-Einträge mindestens 24h.

7. Abnahmekriterien (Auszug)

- Access Token enthält subject_type und scp Array; aud ist Array.
- Resource-Services können Tokens mit aud=strict validieren.
- Service Tokens funktionieren für interne Provisionierung (User/Company/IAM).
- Idempotency für alle Pflicht-Endpunkte ist integriert und getestet (Retry gibt gleiche Antwort).
- tenant_id Regel greift (Mismatch liefert 403 mit errorCode TENANT_MISMATCH).